

VERITRUST

IMPLEMENTATION HANDBOOK | 11 AUGUST 2026

Unified Gateway Architecture Blueprint

An industry-grade control and evidence plane for
Deepfake, Phishing and Link Detection with
durable routing, policy, review and safe enforcement.

- Three existing handbooks cross-analyzed
- Current gateway code and DB.txt mapped
- Expected-evidence ledger and artifact graph
- Models, contracts, policies, queues and release gates

Evidence-first architecture | Modular monolith control plane | Isolated specialist workers



How to use this handbook

Purpose

This is the implementation plan for the unified system above the three specialist engines. It preserves each specialist's scientific meaning and turns complete, versioned evidence into a policy action. It does not replace the Deepfake, Phishing or Link Detection handbooks.

- Read sections 1 to 4 for the cross-analysis and current gaps.
- Use sections 5 to 18 as the target technical specification.
- Execute sections 21 and 22 in order. Do not enable automatic blocking before the listed benchmark and canary gates pass.
- P0 means a correctness, safety, privacy or enforcement problem that blocks production release.
- A specialist emits evidence. Only the Gateway policy plane emits allow, warn, review, hold, quarantine or block.

Table of contents

How to use this handbook	2
Table of contents	3
1. Executive implementation decision	6
Production release blockers	6
2. What the three specialist handbooks require	7
Non-negotiable boundaries	7
Shared vocabulary	7
3. Current gateway implementation	8
What exists now	8
Strong foundations to keep	8
4. Deep findings in the current gateway	9
Routing and model integrity	9
Artifact and correlation integrity	9
Policy, security, operations and UI	9
5. Target principles and boundaries	10
6. Target unified architecture	11
Recommended deployable shape	11
7. Immutable artifact graph	12
Graph contract	12
Required bounds	12
8. Ingress, capabilities and input contracts	13
Capability endpoint	13
Initial production capability	13
9. Route planner and model registry	14
Route plan	14
Registry resolution order	14
Required model-version fields	14
10. Specialist model portfolio in the unified system	15
Deepfake image routes	15
Phishing routes	15
Link routes	15
11. Expected-evidence ledger	16
Why this is the most important change	16
Finalization rule	16
12. Processing modes and deadlines	17
Precise mode contracts	17
Initial budgets - tune with load data	17

13. Unified evidence contract	18
Evidence envelope	18
Contract rules	18
14. Correlation, sufficiency and decision engine	19
Do not average specialist probabilities	19
Decision algorithm	19
Initial cross-signal rules	19
15. Policy-as-code design	20
Policy document v2	20
Lifecycle	20
16. Durable orchestration and queue topology	21
Recommended queues	21
Reliability rules	21
17. Database evolution	22
Keep and strengthen the 22 current tables	22
Required additions	22
18. API, events and webhook contracts	23
Recommended v2 endpoints	23
Event envelope	23
19. Security, privacy and supply chain	24
Threat controls	24
Governance	24
20. Scaling, observability and operations	25
Scalability design	25
Telemetry	25
Initial service objectives	25
21. Product, analyst and admin experience	26
Learner-facing gateway page corrections	26
Analyst review console	26
Admin control plane	26
22. Verification and test architecture	27
Required test layers	27
Golden cross-engine cases	27
23. Ordered implementation roadmap	28
Delivery gates	28
24. First implementation tickets	29
P0 tranche	29
Then build	29

25. Interactive architecture worksheet

Current deployed aliases - exact registry record

3030

26. Interactive production checklist

Release approvals

3232

27. Sources and primary references

VeriTrust source handbooks

Repository evidence reviewed

External primary standards

34343434

1. Executive implementation decision

Decision

Keep the existing 22-table gateway foundation, but replace score-max correlation with an expected-evidence, sufficiency-first decision pipeline. Resolve exact specialist versions before execution, preserve immutable artifact lineage, treat every failure as evidence, and separate advisory decisions from enforcement.

The current gateway has several valuable production ideas: tenant-scoped authentication, idempotent scan submission, versioned policy records, durable queues, upload retention, decision revisions, human review and signed webhooks. The gap is the central truth model. A worker result can be absent, incomparable model scores are treated as if they share one scale, and input modes do not control execution exactly.

Production release blockers

Priority	Finding	Required correction
P0	Model version is looked up while recording evidence, after provider inference	Create a route plan that pins model, processor, calibration and benchmark before any model input is built.
P0	There is no expected-evidence ledger	Persist every required route first. Failed, timed-out, unsupported and dead-lettered routes must remain visible to the final decision.
P0	URL input is canonicalized into one string and raw identity is lost	Store raw, parsed, comparison, network and provider representations separately.
P0	Correlation uses maximum score plus fixed bonuses across unrelated tasks	Evaluate applicability and sufficiency first; use versioned rules, and call risk an index unless it is calibrated.
P0	synchronous, hybrid and asynchronous requests mostly execute the same path	Implement explicit mode contracts, deadlines and allowed terminal responses.
P0	Required media failures can disappear after a job dead-letters	Finalize from the route ledger, never only from evidence rows or actionable jobs.
P0	Audio and video are accepted but have no specialist implementation	Reject them through capabilities until dedicated audio/video pipelines are approved.
P0	Gateway behavior has no complete behavioral test suite	Add unit, database, integration, E2E, adversarial, chaos and load gates.

2. What the three specialist handbooks require

Non-negotiable boundaries

Specialist	Owns	Never owns	Gateway must preserve
Phishing	Email/text parsing, authentication provenance, identity/content observations and semantic evidence	Allow/block action; claims of SPF/DMARC without trusted receiver facts	input mode, MIME lineage, auth trust, child URLs/images, failure and abstention
Link	URL identity, static features, reputation, DNS/RDAP/TLS, redirects and sandbox observations	Universal safety verdict; safe result from no-match or network failure	five URL representations, hop graph, freshness, SSRF boundary and sufficiency profile
Deepfake	Image validation, face/full-frame tracks, quality/OOD, model observations and abstention	Cross-context consequence or enforcement; audio/video without separate models	task identity, derived face artifacts, preprocessing hash, quality, OOD and disagreement
Gateway	Artifact graph, route plan, expected evidence, cross-signal policy, review, enforcement and delivery	Reinterpreting specialist labels or hiding missing evidence	immutable inputs, exact versions, coverage, decision revisions and audit

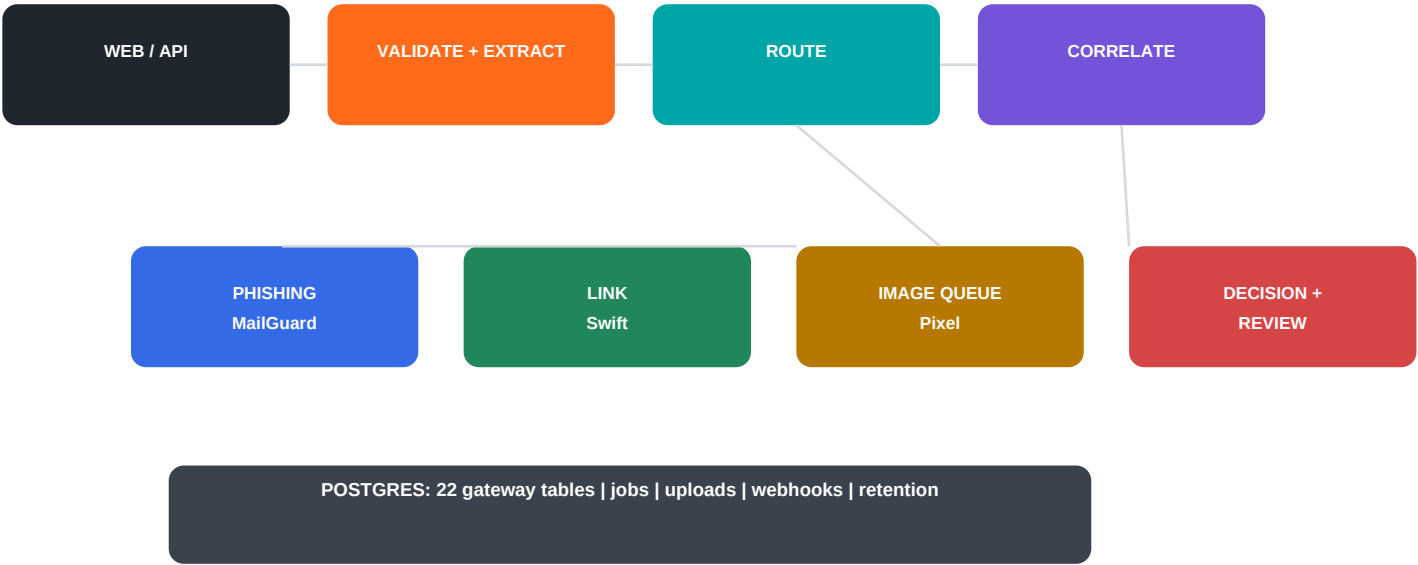
Shared vocabulary

Term	Simple meaning
Artifact	An immutable piece of content or derived content: message, URL, redirect, image, face crop or screenshot.
Observation	One bounded fact from a parser, connector, model or quality check.
Evidence	A signed/versioned collection of observations with status, applicability and provenance.
Sufficiency	Whether the policy-required evidence classes finished with enough quality for a decision.
Decision	A versioned risk interpretation over named evidence IDs.
Recommendation	Advisory output such as warn, review or quarantine.
Enforcement	An external action. It needs separate entitlement, policy, guard and receipt.

Core invariant

No-match, unsupported, timed out, failed, stale, out-of-distribution and low-risk are seven different facts. None may be silently converted into score zero.

3. Current gateway implementation



What exists now

Layer	Current implementation
Ingress	POST/list/get/cancel scans, signed upload registration/completion, policies, webhooks, reviews and operations.
Contract	Schema 1.0; text, URL, image, audio and video; maximum 12,000 text characters, 20 URLs and 10 media items.
Routing	text -> MailGuard, URL -> Swift, image -> Pixel; audio/video become unsupported media jobs.
Fast path	Phishing and Link adapters run in parallel in the API request.
Heavy path	Image work enters gateway_media; workers use leases, heartbeats, retries and reconciliation.
Decision	Maximum completed score, two interaction rules, policy thresholds and an enforcement guard.
Storage	22 gateway tables for policy, scans, idempotency, artifacts, runs, evidence, decisions, jobs, webhooks, review, uploads and retention.
Delivery	Polling, signed webhooks, review overrides, short-lived private uploads and retention receipts.

Strong foundations to keep

- Tenant IDs are used in most service-role repository reads and writes, and API keys are bound to integrations and actions.
- Submission idempotency is protected by an organization/integration/key record and request hash.
- Policy versions and decision revisions are immutable concepts rather than mutable final-result fields.
- Private object storage, generated paths, retention jobs and cleanup receipts already exist.
- Worker queues have database claims, visibility leases, heartbeat, bounded attempts and reconciliation.
- Webhook secrets are encrypted, signatures use HMAC, timestamps support replay checks, and destinations are allowlisted and checked for private IPs.
- Database enforcement prevents automatic block when organization, plan or policy permission is missing.

4. Deep findings in the current gateway

Routing and model integrity

- `DEFAULT_MODELS` hard-codes mailguard, swift and pixel. Policy `model_rollout` exists but does not choose the actual route.
- `recordEvidence` resolves whichever active/canary model version exists after inference. The evidence record can therefore name a version different from the model that ran.
- The fast orchestrator has adapters only for phishing and link. Image is always heavy; audio and video are accepted but never analyzed.
- A dead-lettered image job produces no expected evidence row. Finalization sees no actionable job and can create a final decision from unrelated evidence.
- `processing_mode` is persisted, but routing and waiting behavior do not implement three precise contracts.

Artifact and correlation integrity

- URL canonicalization removes the fragment and normalizes the only stored URL. Forensic raw input and provider-specific identity are unavailable.
- Text URL extraction is a regular expression and has no MIME, HTML, quoted-printable or trusted receiver context.
- A score from phishing, URL classification and deepfake detection is assumed comparable. Maximum score becomes risk, although tasks and calibration scopes differ.
- The 0.12 phishing-link bonus and fixed 0.75/0.90 boundaries are code constants, not benchmark artifacts.
- Required failure applies the `interactive_text_url` failure mode even when the failed artifact is an upload or critical model.
- User-supplied `context_categories` can trigger a consequential deepfake escalation without provenance or authorization.

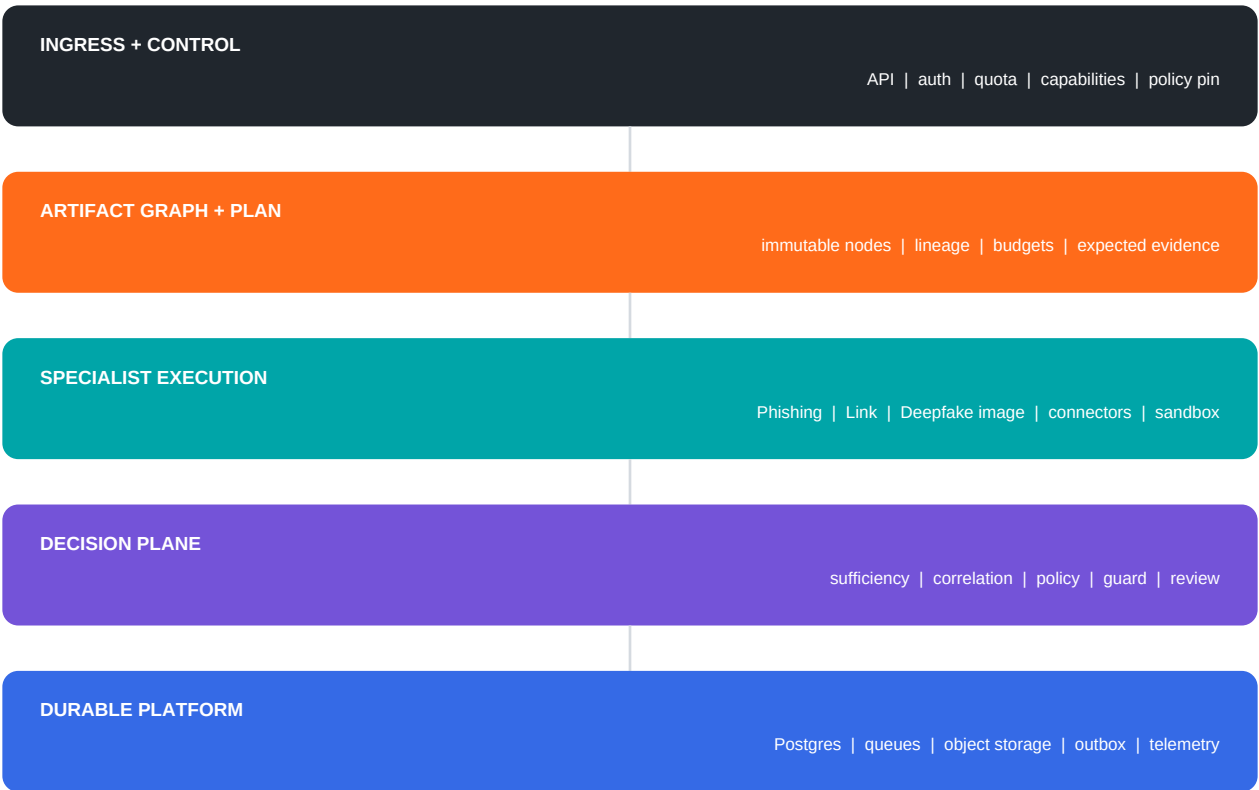
Policy, security, operations and UI

- Nested policy objects such as routing, retention, webhooks and `model_rollout` are not deeply schema-validated.
- Webhook DNS is checked, then `fetch` resolves the hostname again. An allowlist reduces risk, but an egress proxy with pinned approved addresses is safer against rebinding.
- Upload completion trusts storage metadata. Image signatures are checked only later; audio/video bytes are never independently validated because those engines are absent.
- History uses a server limit and client-side show-more, not stable cursor pagination.
- The browser shows risk as a percentage even though current risk is an uncalibrated index. Evidence coverage is not shown.
- The gateway UI contains visible encoding corruption strings for ellipsis, middle dot and em dash.
- No gateway-focused test files were found. The static repository verifier does not test orchestration semantics.

5. Target principles and boundaries

Principle	Required meaning
Evidence before action	Specialists report observations, applicability, quality and failure. They never emit allow or block.
Plan before execution	Policy, model versions, processors, deadlines, requiredness and budgets are pinned in one route plan.
Absence is visible	Every planned unit reaches a terminal state. Missing evidence is itself a decision blocker.
Immutable lineage	Every derived artifact has a parent edge, transform version and hash. Decisions name exact evidence IDs.
Sufficiency before score	The Gateway first asks whether it has the right evidence. Only then does it interpret risk.
Modes are contracts	Synchronous, hybrid and asynchronous behavior is predictable and testable.
Advisory before enforcing	Shadow and advisory operation precede quarantine/block. External action needs an enforcement receipt.
Fail by use case	Failure behavior depends on impact, artifact and integration, not one global default.
Bound every expansion	MIME parts, URLs, redirects, faces, screenshots, retries, bytes and time all consume explicit budgets.
One control plane	Policies, registry, audit and observability are shared; hostile decoders and network/browser workers stay isolated.

6. Target unified architecture

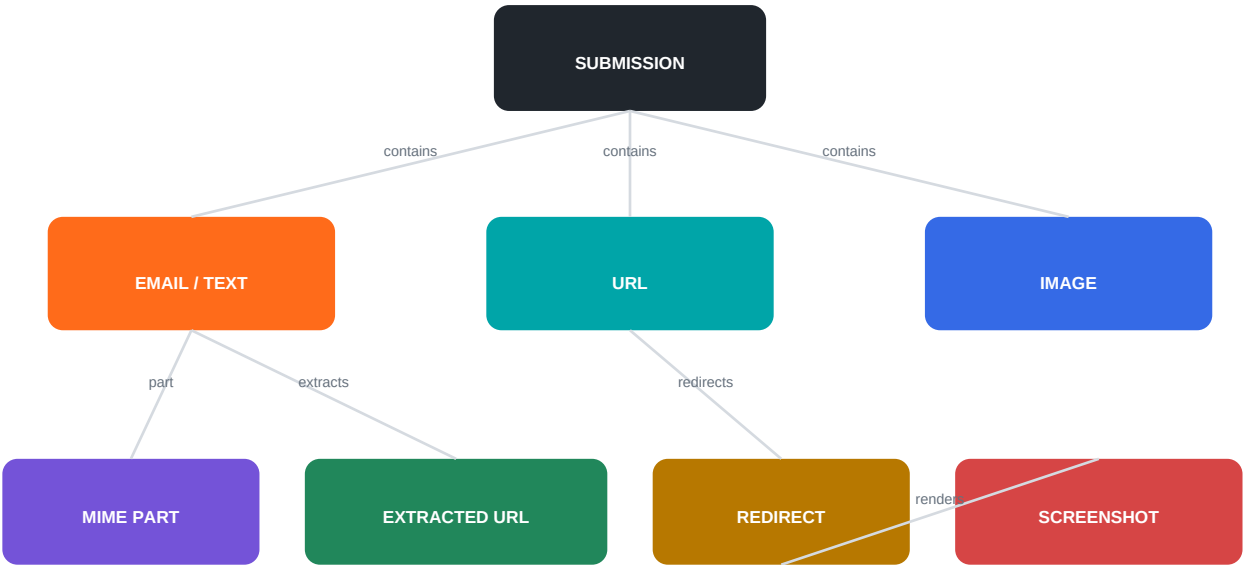


Recommended deployable shape

Start with a modular monolith for the API, policy, registry, artifact graph and decision plane. Run specialist and hostile workloads as separately deployable workers. This keeps transactions simple while allowing GPU, network and browser pools to scale independently.

Component	Responsibility	Isolation/scaling rule
Edge/API	authenticate, authorize, quota, validate envelope, create scan	stateless; no MIME decode, URL dereference or model inference
Planner	pin policy and exact dependencies; build artifact/route budgets	single deterministic implementation; output checksum
Artifact service	immutable nodes, edges, hashes, object references and retention	tenant scoped; content-addressed only inside approved privacy boundary
Specialist adapters	translate pinned artifact contract to Phishing, Link or Deepfake evidence	separate pools and bulkheads by provider/task
Hostile workers	MIME decode, DNS/HTTP/browser, complex media decoding	no application secrets; deny internal egress; ephemeral
Decision service	validate evidence, sufficiency, correlation, policy and revisions	deterministic replay from stored inputs
Control plane	policy lifecycle, model registry, benchmarks, calibration and capability publication	owner/admin roles; four-eyes approval for enforcement
Delivery/review	CloudEvents, webhooks, SSE/polling, analyst cases and enforcement receipts	outbox-driven, idempotent, replayable

7. Immutable artifact graph



Every child has provenance, depth, budget cost and a stable parent edge; loops are impossible by construction

Graph contract

```
ArtifactNode = {
  artifact_id, tenant_id, scan_id, type, media_type,
  raw_ref_or_tenant_hmac, content_sha256, size_bytes,
  parent_edge_id, depth, transform_version, created_at,
  retention_class, sensitivity, provenance
}
ArtifactEdge = {
  edge_id, parent_id, child_id, relation, ordinal,
  extractor_version, observed_at, evidence_ref
}
```

Required bounds

Expansion	Initial bound	On breach
Artifact nodes per scan	32 standard; policy up to 100	stop expansion and emit ARTIFACT_BUDGET_EXCEEDED
Graph depth	4	emit MAX_ARTIFACT_DEPTH
URLs	20 direct/extracted; each redirect chain up to 5	preserve unprocessed count and hold if required
MIME parts	100 headers/parts with decoded byte and nesting budgets	MIME_BUDGET_EXCEEDED
Faces per image	10 qualified faces	record omitted count
Screenshots	1 per final browser page by default	policy-gated additional capture
Cross-routing	one route type per artifact/version; visited-key dedupe	never recursively re-route the same identity

Privacy rule

Do not deduplicate raw content across tenants. Use tenant-derived HMACs for safe matching; keep raw bytes only under explicit retention and region policy.

8. Ingress, capabilities and input contracts

Capability endpoint

```
GET /v2/gateway/capabilities
{
  schema_version, supported_artifacts, supported_modes,
  size_and_count_limits, evidence_profiles,
  enabled_integrations, regions, retention_classes,
  models: [{task, status, input_contract_version}]
}
```

Initial production capability

Input	Initial support	Contract
Plain text	Yes	Fast phishing content evidence plus extracted URLs; no sender authentication claim.
Raw .eml	After Phishing D2	Bounded MIME/local DKIM evidence; async/hybrid; child URL/image routes.
Trusted receiver event	After Phishing D3	Receiver-attested SMTP facts for SPF/DKIM/DMARC/ARC and identity relationships.
Direct URL	Yes after Link parser D1	Five representations, no network in synchronous FAST unless policy explicitly permits.
Image	Yes after Deepfake D2	JPEG/PNG/static WebP; task-selected full-frame and/or face evidence.
Audio/video	No at first	Return UNSUPPORTED_MEDIA_CAPABILITY at registration. Add only through dedicated handbooks, models and benchmarks.

- Use RFC 9457 problem details with stable code, instance, request_id and trace_id.
- Require Idempotency-Key on every mutation and bind it to tenant, integration, API version and canonical request hash.
- Authenticate before signed-upload creation. Bind upload to tenant, integration, declared type/size, expiration and one scan attachment.
- Publish limits from the same versioned capability configuration used by validators and workers.

9. Route planner and model registry

Route plan

```
RoutePlan = {
  plan_id, plan_version, policy_version_id, checksum,
  mode, deadline_at, artifact_budget,
  routes: [{ route_id, artifact_id, specialist, task, tier, required,
    model_version_id, processor_version, calibration_version,
    benchmark_version, timeout_ms, attempts, queue, failure_mode }]
}
```

Registry resolution order



If any required registry field is missing, execution does not start.

Required model-version fields

Field	Requirement
Identity	model_key, scientific task, repository/provider, immutable commit, weight/config/tokenizer/processor digests
Input	artifact type, MIME, dimensions/bytes/tokens, raw/comparison form, preprocessing version
Output	exact label/index map, finite-score schema, observation semantics, error taxonomy
Qualification	calibration artifact, benchmark manifest, slices, robustness, approval and validity window
Supply chain	license checksum/approval, SBOM, signature/provenance, vulnerability/model scan and runtime digest
Rollout	disabled/shadow/canary/production/rolled_back, deterministic cohort and predecessor

Critical ordering

The route plan stores model_version_id before inference. The adapter receives that exact immutable record. Persistence never performs a second active-model lookup while saving the result.

10. Specialist model portfolio in the unified system

Deepfake image routes

Proposed key	Candidate/role	Initial gateway use
face_detector_yunet	OpenCV Zoo YuNet ONNX; face boxes/landmarks only	Preprocessing route; threshold starts at 0.8 for evaluation, NMS 0.3, max 10 faces, minimum face 96x96.
synthetic_commfor_384	OwensLab/commfor-model-384, pinned Safetensors	Primary full-frame fully-synthetic-image evidence at pinned official 384 processor.
synthetic_commfor_224	OwensLab/commfor-model-224	Latency/shadow comparison only until slice gates pass.
face_clip_l14_v1	yermamy/deepfake-detection, CLIP ViT-L/14 candidate	Self-hosted facial manipulation evidence on qualified aligned faces.
forensic_frequency_v1	Private VeriTrust SRM/DCT/noise residual model	Optional independent secondary only after error-correlation value is proven.
media_quality_ood_v1	Deterministic quality plus trained OOD head	Quality and sufficiency; never a synthetic verdict by itself.

Phishing routes

Proposed key	Candidate/role	Initial gateway use
mailguard_current	Exact deployed HF repository is hidden in server config	Disable from production until repository, commit, task, tokenizer and label map are frozen.
phishing_distilbert_v241	cybersectory/phishing-email-detection-distilbert_v2.4.1	Text classifier candidate; return all raw class scores and verify labels with golden fixtures.
phishing_bert_shadow	ealvaradob/bert-finetuned-phishing	Research/shadow diversity; do not promote from card metrics alone.
phishing_mdeberta_v1	Fine-tune microsoft/mdeberta-v3-base	Multilingual/locale-aware primary candidate after governed training and calibration.
phishing_features_gbd_t_v1	Private deterministic identity/content feature model	Independent CPU evidence with explicit missingness.
cortex_semantic_shadow	Mistral-7B-Instruct-v0.3 or approved equivalent	Optional bounded semantic extraction only; temperature 0, strict schema, non-authoritative.

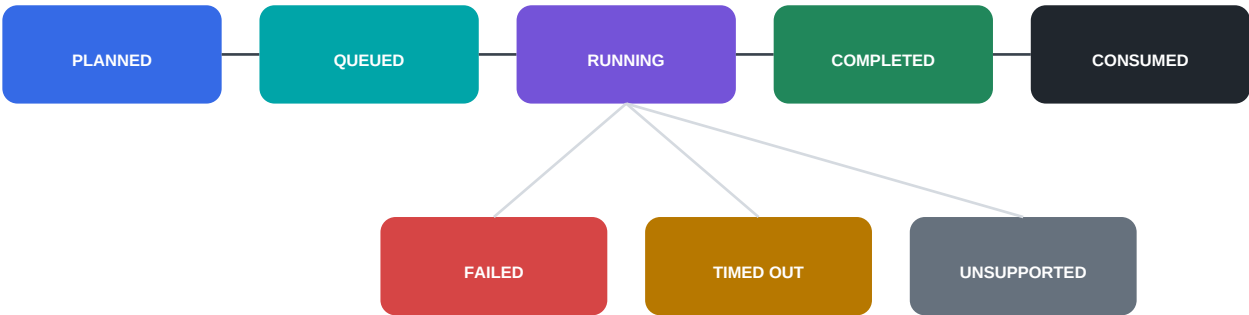
Link routes

Proposed key	Candidate/role	Initial gateway use
urlbert_malicious_v4	CrabInHoney/urlbert-tiny-v4-malicious-url-classifier	Primary fast four-class static model; pinned tokenizer, max length 64, all probabilities.
urlbert_phishing_v4	CrabInHoney/urlbert-tiny-v4-phishing-classifier	Binary shadow until independence is measured.
url_features_gbd_t_v1	Private LightGBM/XGBoost/ONNX	Independent PSL/IDN/structure/encoding/similarity features; target under 10 ms p95 warmed.
page_text_deberta_v1	Fine-tuned microsoft/deberta-v3-small	Async sanitized page text/form evidence after sandbox stability.
brand_siglip2_v1	google/siglip2-base-patch16-224	Future screenshot-brand similarity evidence; not a malicious verdict.
connectors	Web Risk, VirusTotal, URLhaus, PhishTank, DNS, RDAP, TLS, HTTP	Independent observations with source, freshness, privacy and terms controls.

No gateway classifier at first

Use a deterministic, versioned correlation rule set before considering a learned meta-model. Train a meta-model only after the Gateway has leakage-safe, decision-quality labels and can prove calibration, slice safety and rollback.

11. Expected-evidence ledger



A required route never disappears: terminal failure is decision input, not missing data

Why this is the most important change

Today, decision input is built from evidence rows that happen to exist. If a required worker never creates one, it is invisible. The ledger reverses that logic: the planner creates expected units first, workers only transition them, and the finalizer reads every expected unit.

Ledger field	Purpose
route_id + artifact_id	Stable identity and artifact relationship.
required + sufficiency_class	Explains whether the route can block finalization or allow a degraded result.
pinned dependencies	Model, processor, feature, connector, calibration and benchmark versions.
state + attempt	planned, queued, running and one terminal state with lease-safe attempt history.
deadline + failure_mode	Artifact/use-case-specific behavior on timeout or terminal failure.
evidence_id	Present only when completed; immutable evidence remains separate from route state.
terminal reason	FAILED, TIMED_OUT, UNSUPPORTED, CANCELLED or SKIPPED_BY_POLICY with stable reason.

Finalization rule

```
finalize(scan):
  lock scan and route plan
  ensure every route is terminal or force deadline transition
  materialize coverage by artifact and sufficiency class
  validate every completed evidence envelope
  evaluate failure modes for required non-completions
  correlate only qualified/applicable evidence
  publish immutable final decision + outbox atomically
```


12. Processing modes and deadlines

SYNCHRONOUS	HYBRID	ASYNCHRONOUS
validate + plan	fast preliminary	202 accepted
fast specialists	heavy durable jobs	all durable jobs
final or honest hold	immutable final revision	poll / event / webhook

Precise mode contracts

Mode	HTTP behavior	Allowed completion
synchronous	Wait only for policy-declared fast routes inside a strict budget	200 final only if sufficiency is met; otherwise 202/hold with status URL. Never pretend heavy work completed.
hybrid	Run fast routes, publish preliminary, enqueue heavy routes	202 with preliminary revision and coverage; later final revision through poll/event/webhook.
asynchronous	Persist plan and jobs before response	202 accepted after durable commit; no model work is required in the request process.

Initial budgets - tune with load data

Budget	Initial value	Rule
API validation/plan	250 ms p95	No model/network/complex decode.
Synchronous total	2 s default; policy max 5 s	Return honest pending/hold on budget exhaustion.
Fast specialist	1.5 s each with parallel bulkheads	Deadline propagated; no work continues after cancellation without durable ownership.
Hybrid final	15 s target for image and standard link enrichment	Policy may choose longer high-impact profile.
Browser/high-impact	30 s target; hard limit 60 s	Isolated worker, bounded requests/bytes.
Scan deadline	2 minutes default	Planner owns; workers may not extend silently.

13. Unified evidence contract

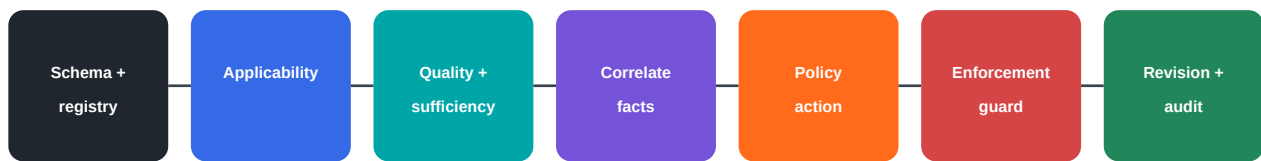
Evidence envelope

```
{
  "schema_version": "gateway-evidence-2",
  "evidence_id": "ev_...", "route_id": "route_...",
  "artifact_id": "art_...", "specialist": "link",
  "task": "malicious_url_classification",
  "status": "COMPLETED|FAILED|TIMED_OUT|UNSUPPORTED",
  "applicability": "APPLICABLE|NOT_APPLICABLE|UNKNOWN",
  "quality": {"state": "QUALIFIED|LIMITED|OOD|UNKNOWN", "reasons": []},
  "observation": {"state": "HIGH_RISK_SIGNAL", "raw_scores": {}},
  "calibrated_probability": null,
  "provenance": {"model_version_id": "...", "processor_version": "..."},
  "observed_at": "...", "fresh_until": null,
  "reason_codes": [], "redacted_detail_ref": null
}
```

Contract rules

- Use one envelope shape, but specialist task schemas remain separate and versioned.
- `raw_score`, `normalized_score`, `calibrated_probability`, `quality` and `decision confidence` are different fields.
- A successful provider response with unknown labels is `FAILED`, not completed low-risk.
- Evidence is append-only. A retry creates an attempt and one terminal route outcome; it does not overwrite prior raw attempt telemetry.
- Indicators are structured objects with `code`, `value`, `unit`, `source` and `feature version`, not free-form strings only.
- Store provenance strength: `user_supplied`, `parser_derived`, `receiver_attested`, `network_observed`, `provider_observed` or `human_verified`.

14. Correlation, sufficiency and decision engine



No cross-engine averaging; actions are policy results, never specialist outputs

Do not average specialist probabilities

A 0.8 phishing probability and 0.8 deepfake probability answer different questions. The decision engine uses evidence states, high-specificity reason codes, provenance and coverage. If a numeric risk index is retained, document that it is a policy index, not an 80% probability of harm.

Decision algorithm

1. Validate schema, route binding and pinned dependency IDs.
2. Classify applicability and quality for every expected route.
3. Compute coverage for the selected sufficiency profile.
4. Apply required-route failure modes before positive correlation.
5. Match versioned cross-signal rules over facts and artifact relationships.
6. Optionally calculate a benchmark-qualified risk index.
7. Map to advisory recommendation through the pinned policy.
8. Apply enforcement entitlement and safety guard.
9. Publish preliminary/final/override revision with exact inputs.

Initial cross-signal rules

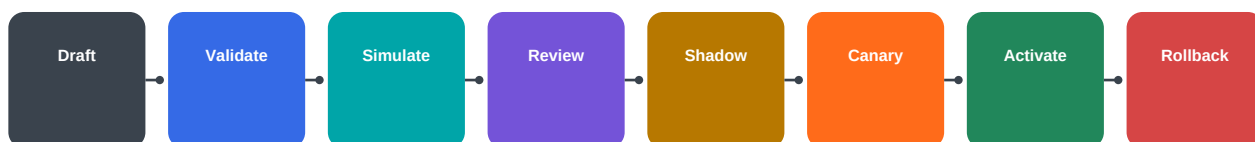
Rule	Evidence requirement	Effect
Phishing + malicious destination	qualified phishing high-risk plus same-message child URL high-risk	raise severity and explanation; no arbitrary score addition
Manipulated identity + consequential request	qualified deepfake high-risk plus trusted context showing financial/credential/identity action	force review or quarantine under high-impact policy
Brand claim mismatch	phishing identity claim plus link/domain mismatch or visual-brand mismatch	high-specificity relationship reason
Trusted reputation hit	current high-confidence connector match tied to exact URL representation	may satisfy high-impact link evidence when provider terms/policy allow
Strong disagreement	qualified independent models disagree outside approved band	UNCERTAIN/REVIEW; never average to the middle
Missing required route	required ledger unit failed/timed out/unsupported	apply use-case failure mode; final decision is degraded

15. Policy-as-code design

Policy document v2

```
policy_v2 = {
  scope: {integrations, source_types, environments, regions},
  capabilities: {allowed_artifacts, modes, evidence_profiles},
  routing: {per_artifact, cross_routes, model_rollouts},
  budgets: {time, bytes, nodes, redirects, retries, concurrency},
  sufficiency: {FAST, STANDARD, HIGH_IMPACT},
  failure_modes: {by_use_case_and_route},
  correlation: {ruleset_version, optional_meta_model_version},
  actions: {thresholds_or_rule_outcomes},
  enforcement: {mode, allowed_actions, approvals, guardrails},
  retention: {content, derived, evidence, region},
  delivery: {events, webhooks, redaction},
  lifecycle: {effective_at, expires_at, predecessor}
}
```

Lifecycle



Activation is atomic; every scan pins one immutable policy version.

- Validate every nested key with JSON Schema plus semantic checks. Unknown keys fail activation.
- Simulation replays a frozen evidence corpus without calling providers and shows decision deltas, action deltas and affected tenants/slices.
- Enforcement policy requires named approvers, plan entitlement, environment scope, maximum blast radius and automatic rollback signals.
- Policy rollback changes the active pointer; it does not mutate historical scans or decisions.
- High-impact policies require minimum evidence, not only a numeric threshold.

16. Durable orchestration and queue topology

Recommended queues

Queue	Workload	Scale signal
gateway_plan	artifact expansion and expected-route creation	oldest age and plan latency
phishing_text_cpu	classifiers/features	queue age, CPU, model batch wait
phishing_email_isolated	MIME/auth/identity	bytes, decoder time, DNS latency
link_static_cpu	parser, static models/features	URL count and p95 latency
link_network	reputation, DNS/RDAP/TLS/HTTP	egress concurrency, provider limits
link_browser	hardened browser jobs	sandbox slots, oldest high-impact age
deepfake_image_gpu	quality, face/full-frame models	GPU memory/utilization and batch delay
gateway_decision	coverage/finalization/replay	oldest terminal-ready scan
gateway_delivery	webhook/events/enforcement receipts	retry age and endpoint health
gateway_retention	object deletion and metadata scrub	overdue retention count

Reliability rules

- Create scan, policy pin, artifact roots, route ledger and outbox jobs atomically before acknowledging async work.
- Use leases, heartbeats and deterministic dedupe keys. Worker completion must be idempotent under redelivery.
- Classify retryable errors. Unknown label, unsupported input and invalid preprocessing are terminal, not retries.
- A dead-letter transition updates the expected route terminal state and schedules decision finalization.
- Cancellation stops new claims, sends cooperative cancellation, records CANCELLED outcomes and still produces an auditable terminal scan state.
- Use per-tenant concurrency and weighted fairness so one bulk integration cannot starve interactive or high-impact work.
- Backpressure rejects or queues before accepting content that cannot meet the declared mode/SLO.

17. Database evolution

Keep and strengthen the 22 current tables

Current cluster	Keep	Strengthen
policies/versions/activations	immutable version and activation history	v2 schema, simulation reports, approvers, effective/expiry dates
integrations/scans/idempotency/usage	tenant, quotas, request identity	source trust, data region, stable cursor, SLO class
artifacts/uploads/retention	private storage and cleanup receipts	raw representation reference, graph edges, transform/hash manifests
model_versions/runs/evidence/health	execution and evidence lineage	exact artifact digests, task contracts, calibration/benchmark/license references
decisions/reviews	immutable revisions and human override	coverage snapshot, rule matches, assignment/SLA, enforcement receipt
jobs/webhook events/attempts/secrets	durable delivery and encrypted secrets	outbox standard, replay endpoint, rotation windows and endpoint health

Required additions

Table	Purpose
gateway_artifact_edges	Immutable parent/child relation, extractor version and provenance.
gateway_route_plans	Pinned policy, budget, mode, checksum and deadline.
gateway_expected_evidence	One row per planned specialist/connector unit and terminal outcome.
gateway_model_artifacts	Weights/config/tokenizer/processor digests, SBOM and signatures.
gateway_calibration_versions	Scope, transform, fit manifest, metrics and approval.
gateway_benchmark_versions	Dataset manifest, leakage controls, slice/robustness results and release gate.
gateway_connectors/cache	Provider identity, privacy/terms policy, observation freshness and circuit health.
gateway_decision_inputs	Coverage snapshot, evidence IDs, rule matches and deterministic replay hash.
gateway_enforcement_receipts	Requested action, target, integration response, idempotency and rollback.
gateway_audit_events	Management/security mutations with actor, request, before/after references.

18. API, events and webhook contracts

Recommended v2 endpoints

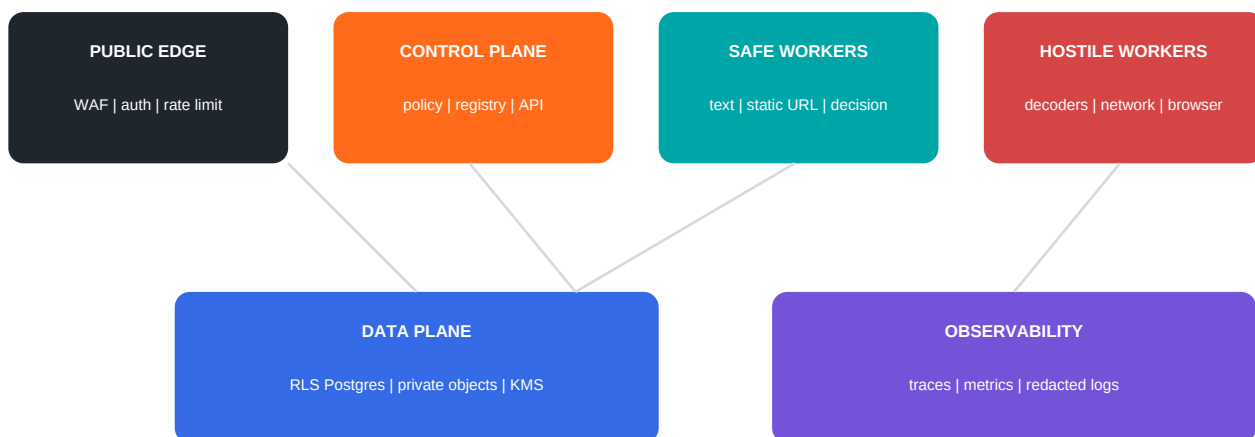
Area	Endpoints
Capabilities	GET /v2/gateway/capabilities
Uploads	POST /v2/gateway/uploads; POST /uploads/:id/complete; DELETE /uploads/:id
Scans	POST /v2/gateway/scans; GET /scans?cursor=; GET /scans/:id; POST /scans/:id/cancel
Evidence/report	GET /scans/:id/report; GET /scans/:id/decisions; GET /scans/:id/events or SSE
Policies	validate, simulate, diff, create version, approve, activate and rollback
Registry	internal model/processor/calibration/benchmark deployment and rollout APIs
Reviews	list with cursor, claim, comment, resolve, reopen and export under role policy
Webhooks	create, rotate secret, disable, test through queue, replay event and view delivery attempts
Operations	health, queues, dead letters, provider circuits, SLO and retention status

Event envelope

```
CloudEvents-compatible fields:
specversion, id, source, type, subject, time, datacontenttype, data
Gateway extensions:
schema_version, tenant_id, scan_id, decision_revision, traceparent
Delivery headers:
event id, timestamp, signature version, key id, content digest
```

- Use W3C traceparent/tracestate between API, queues, workers, providers and deliveries; do not put personal data in tracestate.
- Sign the exact raw webhook bytes, include key ID and support overlapping secrets during rotation.
- Use an egress proxy that connects to the validated public address; revalidate every redirect and prevent DNS rebinding at the network layer.
- Webhook test is a queued delivery event, not an outbound network call inside the management API request.
- Receivers deduplicate by event ID. Gateway retries transient outcomes and offers authorized replay with a new delivery attempt, not a rewritten event.

19. Security, privacy and supply chain



Threat controls

Threat	Required control
Broken tenant/object authorization	org_id in every service-role predicate, integration scope checks, RLS defense, two-tenant tests for every route
SSRF/DNS rebinding	dedicated network identity, approved resolver, deny internal ranges in egress firewall, pin approved address per hop
Decoder/parser exploitation	isolated non-root worker, read-only filesystem, seccomp, bounded bytes/time/nesting and patched pinned image
Model supply chain	commit and digest pinning, Safetensors/ONNX preference, signed build provenance, SBOM, scan, license approval
Prompt injection	treat content as quoted data; strict schema; no tools/secrets; generative output non-authoritative
Webhook abuse	allowlist, HTTPS, encrypted rotating secret, signature/timestamp, replay window, egress proxy and retries
Evidence tampering	append-only records, dependency IDs, canonical decision-input hash, audit and restricted mutation functions
Resource exhaustion	WAF/rate limits, per-tenant quota, artifact budgets, admission control, bulkheads and load shedding
Privacy leakage	purpose/region/retention policy, tenant HMAC, no raw content in logs, redacted reports and verified deletion receipts
Unsafe enforcement	advisory default, two-person approval, blast-radius limit, receipts, rollback and kill switch

Governance

- Apply NIST AI RMF practices to model mapping, measurement, management and governance; pin the framework/profile version used by the program.
- Apply NIST SSDF to source, dependencies, build provenance, vulnerability response and release evidence.
- Use zero-trust principles: authenticate and authorize each workload/resource interaction; network location alone grants no trust.
- Review API controls against OWASP API Security Top 10, especially object authorization, resource consumption, SSRF, inventory and unsafe API consumption.

20. Scaling, observability and operations

Scalability design

- Scale text/static URL CPU pools on queue age and batch delay; scale GPU pools on queue age, memory and utilization; scale browser pools on sandbox slots and network limits.
- Use dynamic batching only within the same exact model/preprocessor version and deadline class.
- Cache connector observations by provider-specific key, privacy boundary and freshness. No-match is never benign and stale is explicit.
- Partition high-volume runs/evidence/jobs/events by time only after query-plan measurements. Keep tenant/time composite indexes and archival strategy.
- Maintain provider circuit breakers, bulkheads and rollout-specific health. A canary failure cannot consume production capacity indefinitely.
- Use admission control before signed upload or scan acceptance when queues cannot meet the selected SLO class.

Telemetry

Signal	Required dimensions
Traces	trace ID, scan, plan, artifact, route, model/connector version, queue attempt and decision revision; no raw content
Metrics	request/route latency, queue age, retries/dead letters, evidence coverage, abstention, degraded/failure and action rates
Model health	score/state distribution, calibration drift, quality/OOD, disagreement, latency, error and slice metrics
Policy health	recommendation/action deltas, overrides, false-positive appeals, simulation/canary drift and rollback triggers
Security	tenant denials, SSRF blocks, parser limits, signature failures, secret rotation and unusual quota patterns
Retention	overdue artifacts, deletion failures, verification receipts and region violations

Initial service objectives

Path	Initial objective
Scan acceptance	99.95% monthly; p95 under 300 ms excluding upload
Fast text/URL	p95 under 2 s warmed; honest hold/pending on budget breach
Hybrid final image/standard URL	p95 under 15 s under declared size and available providers
Decision replay	100% deterministic for same plan/evidence/policy versions
Webhook delivery	99% first attempt within 30 s; at-least-once with idempotent event ID
Retention	99.9% by deadline plus grace; no artifact left without terminal receipt

21. Product, analyst and admin experience

Learner-facing gateway page corrections

- Read capabilities before enabling inputs. Hide or clearly disable audio/video until supported.
- Fix encoding corruption. Use real ellipsis, separators and accessible fallback text in UTF-8 source, or plain ASCII when required.
- Show upload progress, per-file validation, cancellation and safe retry. Do not upload ten large files sequentially without feedback.
- Show artifact tree and route coverage: completed, pending, failed, timed out and unsupported.
- Label current numeric result Risk index, not Risk percent, until calibration proves probability semantics.
- Clearly separate preliminary, final and human override decisions and show when a newer revision is available.
- Use server cursor pagination for history; preserve filters and selection in the URL.

Analyst review console

Area	Required behavior
Queue	priority, SLA, tenant, rule, status, assignee, created time and cursor pagination
Case	artifact graph, coverage, specialist evidence, provenance, policy rule matches and decision history
Safety	redacted content by default, reveal permission, watermark/audit, no active links or raw HTML execution
Action	claim, comment, allow/warn/hold/quarantine/block override, reason taxonomy and second approval
Feedback	structured disposition linked to benchmark/training governance; never automatically train on every override

Admin control plane

- Policy editor with schema help, diff, simulation results, approvers, shadow/canary status and one-click rollback.
- Model registry with exact artifacts, qualification reports, rollout cohort, health and predecessor.
- Webhook secret rotation, replay, endpoint health and delivery attempts.
- Operations dashboard for route coverage, queue age, dead letters, provider circuits, retention and SLO burn.

22. Verification and test architecture

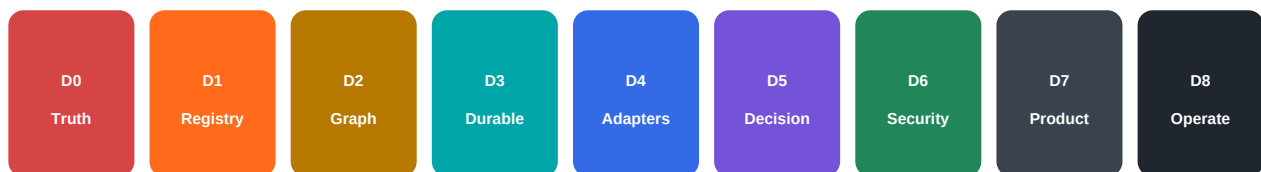
Required test layers

Layer	Must prove
Contract	OpenAPI/JSON Schema compatibility, unknown-field failure, RFC 9457 errors and event schemas
Unit	URL representations, artifact budgets, planner determinism, policy semantics, sufficiency, correlation and guards
Database	tenant isolation, idempotency, immutable dependencies, ledger transitions, leases, outbox and finalization
Adapter	golden labels, unknown/non-finite rejection, exact versions, timeout/retry mapping and redaction
Cross-engine	email -> URL, URL -> redirect/screenshot, image -> faces, disagreement and missing-required-evidence cases
End to end	sync final, hybrid preliminary/final, async event, cancellation, review override, enforcement receipt and retention
Security	object authorization, SSRF/rebinding, parser bombs, MIME polyglots, webhook replay, prompt injection and quota abuse
ML/benchmark	leakage-safe splits, calibration, selective risk, slices, robustness, OOD, drift and rollback parity
Chaos	provider outage, queue redelivery, lease loss, DB retry, dead letter, object loss, webhook failure and region interruption
Load	tenant fairness, upload burst, campaign URL burst, GPU batching, deadline spike and backpressure
Experience	keyboard, screen reader, focus/status messages, responsive layout, slow network and visual regression

Golden cross-engine cases

- High phishing text + malicious child URL -> high-impact rule with both evidence IDs.
- Benign-looking text + required link worker dead-letter -> degraded hold, never allow.
- Manipulated face + user-supplied financial context only -> context provenance prevents automatic high-impact enforcement.
- Trusted receiver authentication pass + malicious URL -> authentication does not cancel malicious child evidence.
- URL reputation no-match + browser timeout -> uncertain/hold under STANDARD or HIGH_IMPACT, not low risk.
- Two model deployments change during a scan -> route plan keeps exact pinned versions and deterministic replay.

23. Ordered implementation roadmap



Production enforcement begins only after benchmark, shadow and canary gates pass

Delivery gates

Gate	Build	Exit evidence
D0 - Truth	Freeze current specialist IDs/tasks, capability contract, vocabularies, source trust and P0 tests.	Every current success/failure meaning is proven by fixtures.
D1 - Registry	Add exact model artifacts, calibration/benchmark records and resolve-before-inference adapters.	Evidence always names the actual executed dependency set.
D2 - Artifact graph	Implement five URL forms, edges, budgets, raw refs and expected-evidence ledger.	No planned route or source identity can disappear.
D3 - Durable modes	Make sync/hybrid/async, deadlines, dead letters, cancellation, outbox and finalizer exact.	Chaos suite reaches correct terminal state every time.
D4 - Specialist adapters	Integrate qualified Phishing, Link and Deepfake image v2 evidence contracts.	Golden schemas, failure mapping and pinned preprocessing pass.
D5 - Decision/policy	Sufficiency profiles, correlation rules, policy v2, simulation, revisions and enforcement guard.	Replay deterministic; false-action benchmark approved.
D6 - Security	Isolated parsers/network/browser, egress proxy, KMS, supply chain, privacy and audit.	Threat model and adversarial tests approved.
D7 - Product	Capability-aware UI, artifact coverage, analyst review, policy/model admin and webhook operations.	Accessibility and misleading-claim review pass.
D8 - Operate/release	SLOs, telemetry, drift, scale/fairness, migration, shadow, canary, rollback and incident drill.	Production enforcement signed and reversible.

24. First implementation tickets

P0 tranche

ID	Acceptance summary
GWY-001	Pin model/processor/calibration/benchmark in route plan before inference.
GWY-002	Add expected-evidence ledger and terminal transitions for failure, timeout, unsupported and dead letter.
GWY-003	Finalize decisions from the ledger and selected sufficiency profile, not existing evidence rows.
GWY-004	Implement raw/parsed/comparison/network/provider URL representations and artifact edges.
GWY-005	Make processing_mode an executable contract with deadlines and response rules.
GWY-006	Reject audio/video through capabilities and upload registration until supported.
GWY-007	Replace score-max correlation and fixed bonuses with versioned fact rules and coverage.
GWY-008	Add artifact/use-case-specific failure modes and trusted context provenance.
GWY-009	Deep-validate policy v2; add validate, simulate, diff, approve, activate and rollback.
GWY-010	Build behavioral database/integration/E2E/chaos tests for all P0 paths.
GWY-011	Move webhook tests to queue; add pinned-address egress delivery and secret rotation.
GWY-012	Repair Gateway UI encoding, capabilities, evidence coverage and risk-index wording.

Then build

- GWY-013 - specialist evidence v2 adapters and exact model matrix.
- GWY-014 - isolated MIME, network and browser workers with route budgets.
- GWY-015 - analyst case assignment/SLA and safe evidence viewer.
- GWY-016 - W3C trace context, OpenTelemetry and redacted structured logs.
- GWY-017 - stable cursor pagination, event stream and webhook replay operations.
- GWY-018 - load/fairness, shadow/canary automation, drift and enforcement kill switch.

25. Interactive architecture worksheet

Fill these before coding model-dependent or enforcement behavior. Blank fields identify unresolved product or governance decisions.

Primary gateway use cases	
High-impact actions	
Expected daily scans	
Peak scans per second	
Peak concurrent image jobs	
Required regions/residency	
Synchronous SLO	
Hybrid final SLO	
Default evidence profile	
Content retention	
Evidence retention	
Review owner and SLA	
Enforcement integration	
Canary population/duration	
Rollback trigger	
Incident owner	

Current deployed aliases - exact registry record

MailGuard repository@commit	
-----------------------------	--

MailGuard task/labels

Cortex model/role

Swift repository@commit

Swift task/labels

Sentinel exact role

Pixel repository@commit

Pixel task/labels

Prism repository@commit

Prism task/labels

26. Interactive production checklist

- ☐ All specialist tasks, labels, exact commits, artifacts and licenses are frozen
- ☐ Route plan pins policy and every dependency before any execution
- ☐ Expected-evidence ledger makes every required failure visible
- ☐ Raw URL and all four derived URL representations are preserved
- ☐ Artifact graph budgets prevent loops and expansion bombs
- ☐ Sync, hybrid and async mode contracts pass E2E
- ☐ Audio/video are rejected until dedicated capabilities are approved
- ☐ Specialists never emit actions and Gateway never rewrites specialist truth
- ☐ Sufficiency is evaluated before correlation
- ☐ Risk is labelled an index unless calibration proves probability
- ☐ Policy v2 nested schema, simulation and rollback pass
- ☐ Required failure modes are selected by route and use case
- ☐ Context provenance is trusted before consequential escalation
- ☐ Dead-letter and lease-loss chaos tests produce correct final states
- ☐ Webhook delivery is queued, signed, rotating and rebinding-resistant
- ☐ Hostile parsers/network/browser workers have no application secrets
- ☐ Every service-role access has two-tenant authorization tests
- ☐ Model artifacts have digest, SBOM, scan and license approval
- ☐ W3C trace context and redacted OpenTelemetry cover every route
- ☐ UI shows capabilities, coverage and preliminary/final revisions
- ☐ Accessibility and visual regression pass on all gateway workflows
- ☐ Load test proves tenant fairness and declared SLOs
- ☐ Shadow benchmark and canary approval are complete
- ☐ Enforcement guard, receipts, kill switch and rollback drill pass
- ☐ Retention cleanup and verification receipts meet the policy

Release approvals

Architecture

Security/privacy

ML/model risk

Product/UX

SRE/operations

Production date

27. Sources and primary references

VeriTrust source handbooks

- VeriTrust Deepfake Detection Implementation Handbook - 26 pages, 38 interactive fields.
- VeriTrust Phishing Detection Implementation Handbook - 25 pages, 59 interactive fields.
- VeriTrust Link Detection Implementation Handbook - 27 pages, 49 interactive fields.

Repository evidence reviewed

- `api/gateway.js`; `openapi/veritrust-gateway-v1.yaml`; `gateway.html`; `gateway-powershell.html`; `assets/js/pages/gateway.js`; `assets/css/pages/gateway.css`.
- `lib/gateway/contracts.js`, `orchestrator.js`, `router.js`, `extractor.js`, `correlation.js`, `policy.js`, `persistence.js`, `uploads.js`, `webhooks.js` and worker modules.
- `worker/index.js` and media, webhook and retention handlers.
- `DB.txt` gateway schema: 22 gateway tables and the deployed submit, queue, evidence and decision functions.

External primary standards

1. NIST SP 800-207, Zero Trust Architecture. <https://csrc.nist.gov/pubs/sp/800/207/final>
2. NIST AI Risk Management Framework 1.0 and current program resources. NIST notes that AI RMF 1.0 is being revised; pin the version used. <https://www.nist.gov/itl/ai-risk-management-framework>
3. NIST SP 800-218, Secure Software Development Framework 1.1. <https://csrc.nist.gov/pubs/sp/800/218/final>
4. W3C Trace Context Recommendation. <https://www.w3.org/TR/trace-context/>
5. RFC 9457, Problem Details for HTTP APIs. <https://www.rfc-editor.org/rfc/rfc9457.html>
6. OWASP API Security Top 10 - 2023. <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>
7. CNCF CloudEvents specification resources. <https://cloudevents.io/>
8. OpenTelemetry Specification. <https://opentelemetry.io/docs/specs/otel/>

Implementation starting point

Start with GWY-001 through GWY-010. The first safe milestone is a deterministic route plan and expected-evidence ledger that can replay one text + URL + image scan without losing any failed specialist route. Automatic enforcement remains off.

END OF HANDBOOK